BÁO CÁO THỰC HÀNH SỐ 1

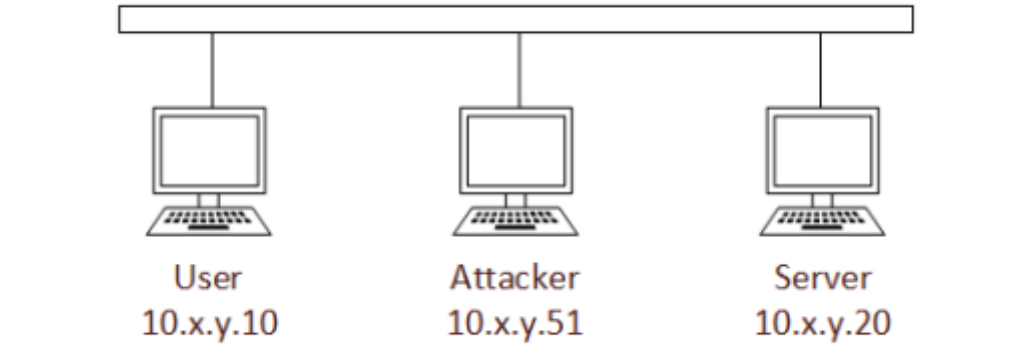
PHÂN TÍCH CÁC KỸ THUẬT DO THÁM HỆ THỐNG

Họ và tên: Phạm Quỳnh Chi
Lớp: CNTT D2023B
MSV: 223001699

Yêu cầu kết quả thực hành:

KẾT QUẢ THỰC HÀNH

Tạo 3 máy ảo trên docker




```
Creating lab02_user     ... done
duylm@ubuntu:~/it4263lab/lab02$ docker ps
CONTAINER ID   IMAGE           COMMAND       CREATED          STATUS          PORTS     NAMES
f51816637e14   lab02_user      "/bin/bash"   10 seconds ago   Up 7 seconds              lab02_user
c3f0fc6494a8   lab02_server    "/bin/bash"   10 seconds ago   Up 8 seconds              lab02_server
d76d9a605086   lab02_attacker  "/bin/bash"   10 seconds ago   Up 7 seconds              lab02_attacker
```

Thông số của các container trước khi thực hiện tấn công

Kiểm tra ip/mã và bảng arp trong arp cache mỗi máy (nơi lưu địa chỉ các máy khác

công ARP Cache Poisoning: kỹ thuật gửi gói tin ARP với địa chỉ MAXC giả/ mac của máy tấn công khiến máy nạn nhân gửi tin sáng máy attack chứ ko phải máy đích.

- Máy User:
  - Địa chỉ IP: 10.11.1.10
  - Địa chỉ MAC: 02:42:0a:0b:01:0a
  - Bảng ánh xạ ARP

```
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user ifconfig eth0
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 10.11.1.10  netmask 255.255.255.0  broadcast 10.11.1.255
        ether 02:42:0a:0b:01:0a  txqueuelen 0  (Ethernet)
        RX packets 53  bytes 8683 (8.6 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 0  bytes 0 (0.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

-

```
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user arp -n
Address                  HWtype  HWaddress           Flags Mask            Iface
10.11.1.1                ether   02:42:83:a5:6b:6f   C                     eth0
10.11.1.20               ether   02:42:0a:0b:01:14   C                     eth0
```

-

Máy Server:

- Địa chỉ IP: 10.11.1.20
- Địa chỉ MAC: 02:42:0a:0b:01:14
- Bảng ánh xạ ARP

```
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_server ifconfig eth0
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 10.11.1.20  netmask 255.255.255.0  broadcast 10.11.1.255
        ether 02:42:0a:0b:01:14  txqueuelen 0  (Ethernet)
        RX packets 71  bytes 10919 (10.9 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 5  bytes 378 (378.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_server arp -n
Address                  HWtype  HWaddress           Flags Mask            Iface
10.11.1.10               ether   02:42:0a:0b:01:0a   C                     eth0
```

-

Máy Attacker:

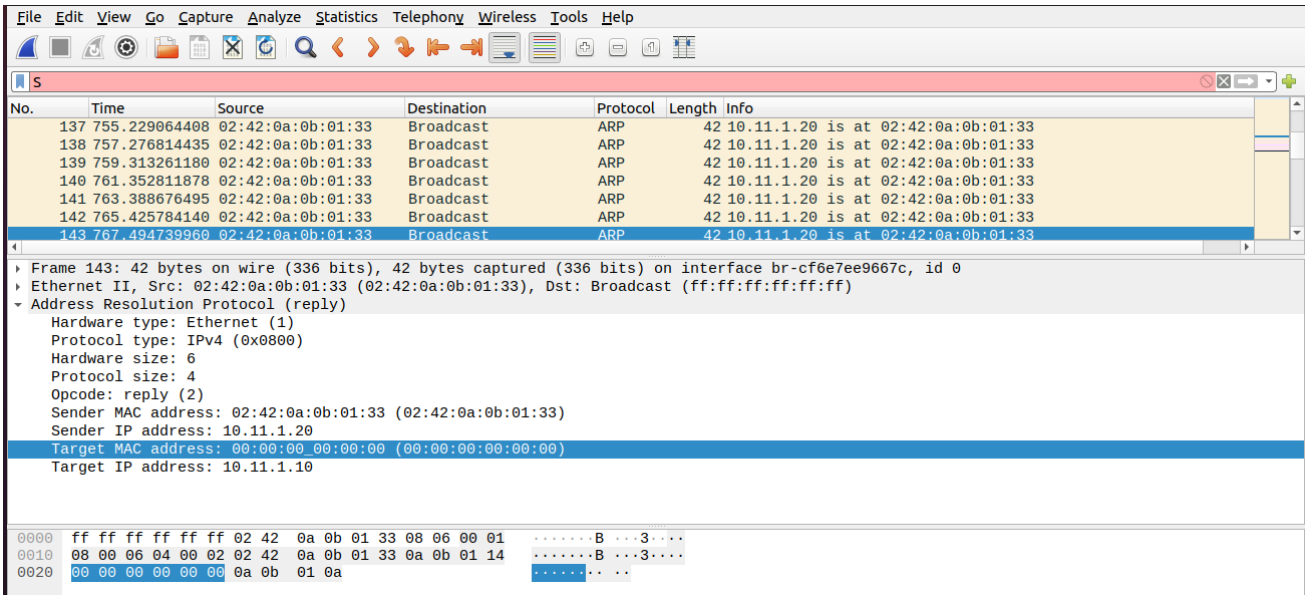
- Địa chỉ IP: 10.11.1.51
- Địa chỉ MAC: 02:42:0a:0b:01:33

```
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_attacker ifconfig eth0
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 10.11.1.51  netmask 255.255.255.0  broadcast 10.11.1.255
        ether 02:42:0a:0b:01:33  txqueuelen 0  (Ethernet)
        RX packets 65  bytes 10363 (10.3 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 0  bytes 0 (0.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

Kịch bản 1 (2 điểm)

Phân tích lưu lượng tấn công và kết quả quan sát được để trả lời các câu hỏi sau:

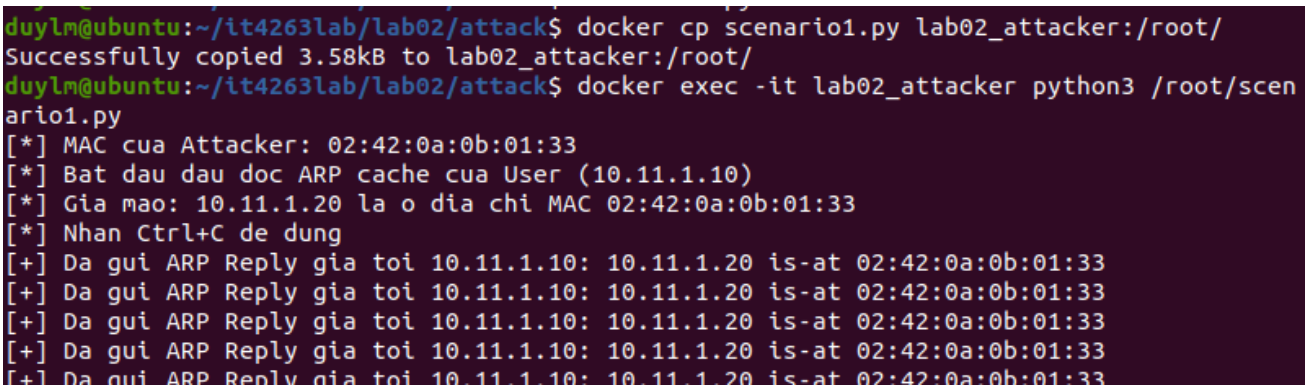
- Tìm gói tin mà máy tấn công đã gửi đi để thực hiện tấn công ARP Cache Poisoning. ***(1 điểm)***



  - Số thứ tự (No.): 108
  - Địa chỉ nguồn: 10.11.1.20
  - Địa chỉ đích: 10.11.1.10
  - Loại gói tin là ARP Request hay ARP Reply? ARP Reply
  - Đặc điểm khác thường của gói tin này so với thông tin thực tế của mạng là gì? MAC là của Attack chứ không phải của Server thật
- Theo các thông tin đã phân tích từ trên, máy nào đã bị tấn công? Hậu quả của tấn công trên máy nạn nhân là gì? ***(1 điểm)*** Máy User bị tấn công dẫn đến địa chỉ MAC Máy Server mà User lưu bị thay đổi sai

  Chi tiết:

- Bắt đầu chạy lệch gửi tin tặc tới ip user, và user cũng ko có kiểm duyệt nên đã đè lên cache cũ



- Máy user đã bị đầu độc thành công – mã của server đổi thành mac của attack

-
```
duylm@ubuntu:~$ docker exec -it lab02_user arp -n
Address                  HWtype  HWaddress           Flags Mask            Iface
10.11.1.1                ether   02:42:83:a5:6b:6f   C                     eth0
10.11.1.20               ether   02:42:0a:0b:01:14   C                     eth0
duylm@ubuntu:~$ docker exec -it lab02_user arp -n
Address                  HWtype  HWaddress           Flags Mask            Iface
10.11.1.1                ether   02:42:83:a5:6b:6f   C                     eth0
10.11.1.20               ether   02:42:0a:0b:01:33   C                     eth0
```

- Ping từ user tới host: giả thuyết là loss hết nhưng lại nhận hết

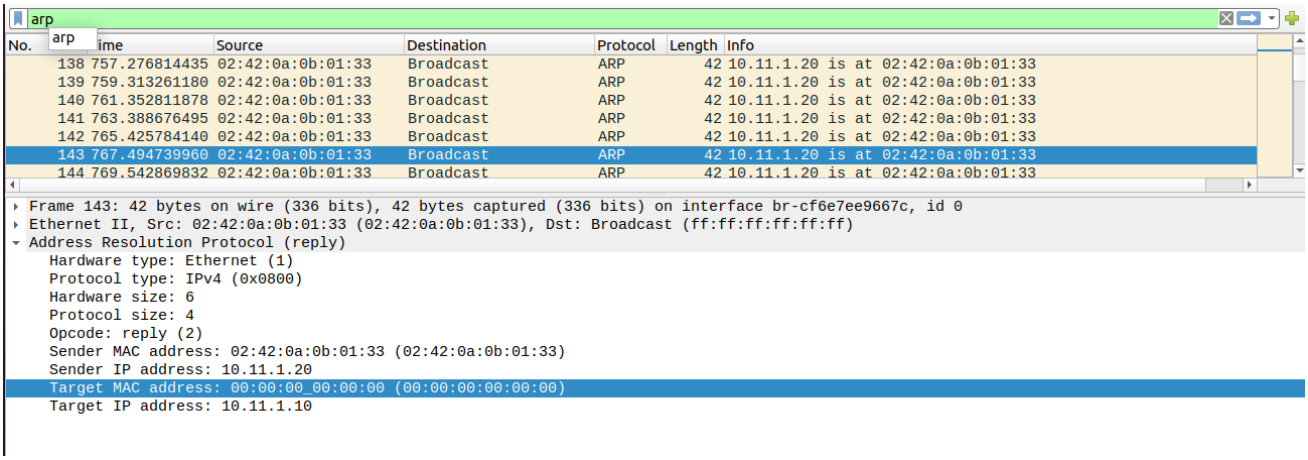
-
```
duylm@ubuntu:~$ docker exec -it lab02_user ping -c 3 10.11.1.20
PING 10.11.1.20 (10.11.1.20) 56(84) bytes of data.
64 bytes from 10.11.1.20: icmp_seq=1 ttl=64 time=0.612 ms
From 10.11.1.51 icmp_seq=2 Redirect Host(New nexthop: 20.1.11.10)
64 bytes from 10.11.1.20: icmp_seq=2 ttl=64 time=0.219 ms

--- 10.11.1.20 ping statistics ---
2 packets transmitted, 2 received, +1 errors, 0% packet loss, time 1006ms
rtt min/avg/max/mdev = 0.219/0.415/0.612/0.196 ms
```

-
```
duylm@ubuntu:~/it4263lab/lab02/attack$ docker exec -it lab02_user ping -c 3 10.11.1.20
PING 10.11.1.20 (10.11.1.20) 56(84) bytes of data.

--- 10.11.1.20 ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2049ms
```

- Ban đầu Attacker kế thừa net.ipv4.ip_forward=1 từ Docker host nên vô tình đóng vai trò router, khiến traffic vẫn tới đích qua ICMP Redirect. Nhóm đã khắc phục bằng cách đặt chính sách iptables -P FORWARD DROP trên Attacker để đảm bảo đúng ngữ cảnh tấn công ARP poisoning thuần túy (không chuyển tiếp dữ liệu).

- 

Quát trên attack Bảng arp cho thấy các gói tin có ip của server nhưng mac lại của attack

Phòng chống tấn công

Gốc rễ lỗ hổng ARP là: **bảng ARP cache mặc định là "dynamic"** (động) — bất kỳ gói Reply nào đến cũng được phép ghi đè, không cần xác thực. Giải pháp phòng chống ở đây là biến một entry cụ thể từ "dynamic" sang **"static"** (tĩnh) — khi đó, hệ điều hành **khóa cứng** ánh xạ IP↔MAC đó lại, từ chối mọi gói ARP Reply (kể cả giả mạo) cố gắng ghi đè lên nó.

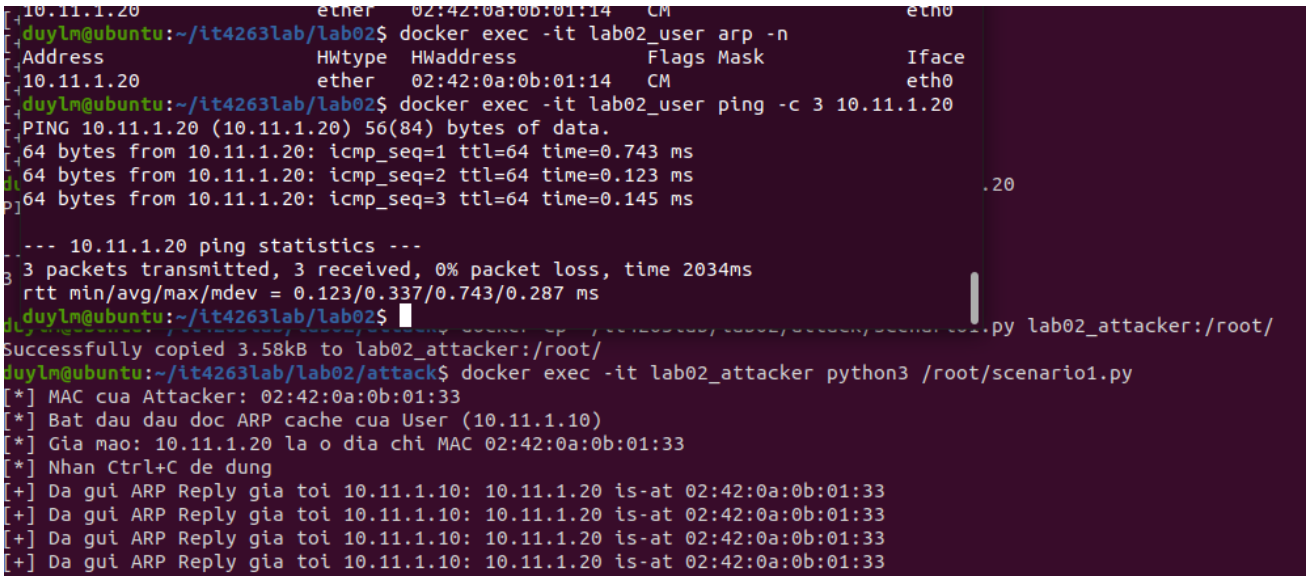
Đây chính là lý do ở bảng ARP bạn thấy cột Flags — entry bình thường có cờ C (Complete/dynamic), còn static entry sẽ có cờ M (Permanent/static).

Hạn chế thực tế của giải pháp này (đáng đưa vào báo cáo để thể hiện tư duy phản biện): chỉ khả thi với mạng rất nhỏ, vì phải khai báo thủ công cho **từng cặp máy** — không scale được với mạng doanh nghiệp có hàng trăm thiết bị, và không chống được nếu Attacker giả mạo DHCP hoặc tấn công DNS thay vì ARP.

Restart 3 máy để đặt ARP cache về rỗng – chạy lệch fix tĩnh địa chỉ của server – thử tấn công lại và thấy user không còn bị ảnh hưởng

```
duylm@ubuntu:~/it4263lab/lab02$ docker-compose restart user attacker server
Restarting lab02_attacker ... done
Restarting lab02_user     ... done
Restarting lab02_server   ... done
duylm@ubuntu:~/it4263lab/lab02$ sleep 3
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user ping -c 2 10.11.1.20
PING 10.11.1.20 (10.11.1.20) 56(84) bytes of data.
64 bytes from 10.11.1.20: icmp_seq=1 ttl=64 time=2.38 ms
64 bytes from 10.11.1.20: icmp_seq=2 ttl=64 time=0.146 ms

--- 10.11.1.20 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.146/1.262/2.378/1.116 ms
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_server ifconfig eth0 | gre
p ether
        ether 02:42:0a:0b:01:14  txqueuelen 0  (Ethernet)
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user arp -s 10.11.1.20 02:
42:0a:0b:01:14
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user arp -n
Address                  HWtype  HWaddress           Flags Mask            Iface
10.11.1.20               ether   02:42:0a:0b:01:14   CM                    eth0
```


10.11.1.20 ether 02:42:0a:0b:01:14 CM eth0
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user arp -n
Address HWtype HWaddress Flags Mask Iface
10.11.1.20 ether 02:42:0a:0b:01:14 CM eth0
duylm@ubuntu:~/it4263lab/lab02$ docker exec -it lab02_user ping -c 3 10.11.1.20
PING 10.11.1.20 (10.11.1.20) 56(84) bytes of data.
64 bytes from 10.11.1.20: icmp_seq=1 ttl=64 time=0.743 ms
64 bytes from 10.11.1.20: icmp_seq=2 ttl=64 time=0.123 ms
64 bytes from 10.11.1.20: icmp_seq=3 ttl=64 time=0.145 ms
--- 10.11.1.20 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2034ms
rtt min/avg/max/mdev = 0.123/0.337/0.743/0.287 ms
duylm@ubuntu:~/it4263lab/lab02$
.20
.py lab02_attacker:/root/
Successfully copied 3.58kB to lab02_attacker:/root/
duylm@ubuntu:~/it4263lab/lab02/attack$ docker exec -it lab02_attacker python3 /root/scenario1.py
[*] MAC cua Attacker: 02:42:0a:0b:01:33
[*] Bat dau dau doc ARP cache cua User (10.11.1.10)
[*] Gia mao: 10.11.1.20 la o dia chi MAC 02:42:0a:0b:01:33
[*] Nhan Ctrl+C de dung
[+] Da gui ARP Reply gia toi 10.11.1.10: 10.11.1.20 is-at 02:42:0a:0b:01:33
[+] Da gui ARP Reply gia toi 10.11.1.10: 10.11.1.20 is-at 02:42:0a:0b:01:33
[+] Da gui ARP Reply gia toi 10.11.1.10: 10.11.1.20 is-at 02:42:0a:0b:01:33
[+] Da gui ARP Reply gia toi 10.11.1.10: 10.11.1.20 is-at 02:42:0a:0b:01:33